

AI-Powered Expense Claims System

Product Specification, Policy Limits, Architecture & Workflow Guide

1. Executive Summary & Product Mission

The **Expense Claims & Forensic Verification System** is an enterprise-grade corporate platform designed to eliminate fraudulent or duplicate out-of-pocket reimbursements while delivering a zero-friction experience for employees. By fusing **Google Gemini Vision OCR** with a multi-signal deterministic similarity engine and structured separation of duties between Managers and Financial Controllers, the system guarantees speed, mathematical precision, and regulatory compliance.

Key Differentiators:

- **Gemini Vision AI:** Instant OCR line-item extraction from receipts (PDF, PNG, JPG).
- **Forensic Duplicate Engine:** Exact hash matches + Levenshtein merchant distance + date/amount variance.
- **Separation of Duties:** Managers evaluate business necessity; Finance evaluates cross-company duplication.
- **Terminal Paid State:** Immutable payment settlement via PaymentService (prevents double payout).

2. Financial Limits, Thresholds & Policy Rules

Every claim is evaluated against deterministic organizational thresholds:

Rule / Policy	Value / Ceiling	Type	Description & Rationale
Minimum Claim Amount	■1.00	Enforced	Claims cannot be ■0 or negative.
Per-Claim Ceiling	■10,000	Policy Cap	Standard limit for staff claims. Amounts above ■10,000 require director escalation.
Tax & Audit Threshold	■5,000	Mandate	Claims > ■5,000 require verified GST/Tax identification & item matching before clearance.
Receipt Upload	Mandatory	Enforced	Valid receipt strictly required for all reimbursable claims.
Stale Receipt Window	90 Days	Rule	Receipts older than 90 days are flagged as STALE_RECEIPT for manager inspection.
Max File Size	10 MB	Enforced	Maximum allowable file size per receipt attachment.
Allowed Formats	PDF, PNG, JPG, WEBP	Enforced	Strict MIME-type validation to prevent malicious uploads.
Base Currency	INR (■)	Standard	Base operating currency; foreign currencies normalized to INR.

3. Roles & Segregation of Duties

Role / User	Primary Competency	Allowed Actions & Constraints
Staff (Employee) Vickey Kumar (usr-001)	Submits out-of-pocket expenses	• Upload receipts & trigger Gemini OCR extraction. • Adjust line items before submitting. • Cannot approve own claims or alter statuses.
Approving Manager Rahul Sharma (usr-mgr-001)	Validates business context & expense necessity	• Approve clean claims (routes to payment). • Confirm business context on FLAGGED claims. • Reject invalid claims with mandatory comment. • Self-approval structurally blocked.
Financial Controller Anita Joshi (usr-fin-001)	Adjudicates company-wide financial integrity	• Inspect cross-company duplicate signals. • Clear financial exceptions with audit justification. • Execute simulated bank payouts (TXN-PAY-...). • Cannot pay claims prior to READY_FOR_PAYMENT.

4. End-to-End Lifecycle & State Machine

Claims follow a deterministic, dual-path state machine based on the automated verification score:

Phase	State	Path & Transition Event
1. Ingestion	DRAFT	Employee creates claim and uploads receipt. Gemini Vision auto-fills details.
2. Submission	SUBMITTED	Employee confirms details and submits. Automated Verification Engine executes.
3A. Clean Path	CLEAN → APPROVED	Score < 40%. Direct to Manager. Manager approves → READY_FOR_PAYMENT.
3B. Flagged Path	FLAGGED	Score >= 40% (duplicate risk). Requires dual review sign-off.
4. Context Signoff	MANAGER_CONFIRMED	Manager reviews duplicate evidence, confirms business legitimacy with required comment.
5. Finance Clearance	READY_FOR_PAYMENT	Finance reviews cross-department evidence, clears exception → Queued for payout.
6. Disbursement	PAID (Terminal)	Finance executes payment. Payment reference logged. State is permanent and immutable.
Exception	REJECTED	Available at Manager or Finance stage with required written reason.

5. AI Verification & Forensic Engine Architecture

To maximize speed and minimize LLM API token consumption, verification is executed in 3 tiers:

- **Tier 1 (Fast Retrieval):** Indexed database search for historical candidates matching merchant or date proximity.
- **Tier 2 (Deterministic Scoring):** File SHA-256 hash comparison, Levenshtein merchant distance, exact date delta, and invoice number match.
- **Tier 3 (Gemini Forensic Analysis):** Only triggered when similarity score is in the ambiguous/borderline zone (40% - 100%). Gemini generates duplicate risk percentage, risk classification (LOW / MEDIUM / HIGH), forensic explanation, and manager recommendations.

6. Payment Execution & Settlement Guardrails

- **Provider Abstraction:** Built using PaymentProvider interface and MockPaymentProvider simulating instant UPI/NEFT banking settlement.
- **Reference Generation:** Generates unique reference code: TXN-PAY-{YYYYMMDD}-{HEX6}.
- **Terminal State Guardrail:** Attempting to pay an already PAID claim returns HTTP 409 Conflict.
- **Prerequisite Guardrail:** Only claims in READY_FOR_PAYMENT status can be disbursed.

7. SLA & Turnaround Duration Tracking

- **Immutable Log:** Every transition is recorded in claim_status_history with actor name, timestamps, and comments.
- **Step SLA Metrics:** UI computes elapsed duration between every step (e.g. +27s draft to verification, +1h 45m submission to manager review).
- **End-to-End Cycle Time:** Automatically calculates total turnaround time from creation to payout (e.g. ■ Turnaround: 2h 15m).

8. Future Work & Scalability Roadmap (Scaling 1 to 100,000+ Users)

- **Production Code Hardening:** Enforce strict static typing (mypy --strict), ClamAV virus scanning for uploads, binary magic-byte MIME validation, and circuit breakers (tenacity) for third-party AI APIs.
- **Observability & Grafana Telemetry:** Prometheus metrics exporter (RPS, error rate, p99 latency, DB pool saturation, Gemini token burn) paired with custom Grafana dashboards and OpenTelemetry distributed tracing.
- **High-Concurrency Architecture:** Offload heavy OCR and forensic analysis to asynchronous worker queues (Celery/ARQ with Redis). Deploy PgBouncer connection pooling and read replicas for analytical queries.
- **FinOps & Token Optimization:** Exact SHA-256 hash caching to bypass redundant Gemini API calls. Tiered gating ensures clean claims incur \$0 LLM expense.
- **Multi-Tier Rate Limiting:** Redis token-bucket rate limiters (per-IP, per-user upload quotas, AI endpoint burst caps) fronted by Cloudflare WAF.
- **Enterprise IAM & RBAC:** Transition from mock auth to enterprise SSO (OAuth 2.0 / SAML 2.0 / Entra ID / Google Workspace) with cryptographically signed JWTs.
- **Automated Load & Stress Testing:** Locust & k6 test suites simulating 1,000 to 100,000 concurrent active users to validate sub-300ms p99 latency and zero data-loss resilience.
- **Banking & ERP Integrations:** Direct webhook integration with corporate disbursement rails (RazorpayX, Stripe Treasury, IMPS/NEFT) and automated ERP sync (SAP, Oracle NetSuite, QuickBooks).